

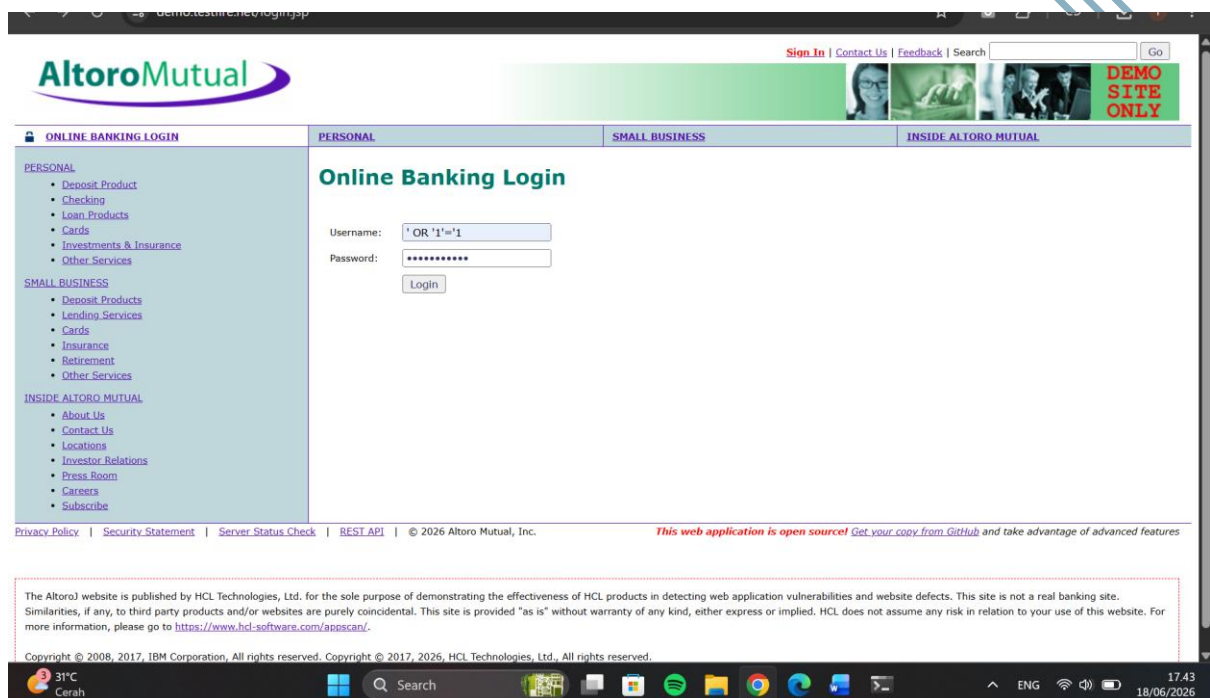
Soal 4 Kelompok 5

Nama kelompok :

Crishtiano Samuel sapan 241011063

Gad 241011015

Rahma aulia 241011103



Berdasarkan gambar yang ditampilkan, dilakukan pengujian kerentanan **SQL Injection** pada halaman login aplikasi web Altoro Mutual. Pada kolom username dimasukkan payload ' OR '1'='1, sedangkan kolom password diisi sembarang. Payload tersebut digunakan untuk memanipulasi query SQL yang dijalankan oleh server sehingga kondisi pada perintah SQL selalu bernilai benar (TRUE). Jika aplikasi tidak memiliki mekanisme validasi input yang baik, maka penyerang dapat melewati proses autentikasi tanpa mengetahui username dan password yang sebenarnya. Kerentanan ini termasuk dalam kategori SQL Injection (SQLi), yaitu serangan yang memanfaatkan kelemahan aplikasi dalam menangani input pengguna yang berinteraksi langsung dengan database.

demo.testfire.net/bank/main.jsp

Ask Gemini

Sign Off | Contact Us | Feedback | Search

Go

AltoroMutual

MY ACCOUNT

I WANT TO ...

- View Account Summary
- View Recent Transactions
- Transfer Funds
- Search News Articles
- Customize Site Language

ADMINISTRATION

- Edit Users

PERSONAL

SMALL BUSINESS

INSIDE ALTORO MUTUAL

Hello Admin User

Welcome to Altoro Mutual Online.

View Account Details: 800000 Corporate GO

Congratulations!

You have been pre-approved for an Altoro Gold Visa with a credit limit of \$10000!

Click [Here](#) to apply.

Privacy Policy | Security Statement | Server Status Check | REST API | © 2026 Altoro Mutual, Inc.

This web application is open source! Get your copy from GitHub and take advantage of advanced features

The Altoro) website is published by HCL Technologies, Ltd. for the sole purpose of demonstrating the effectiveness of HCL products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. HCL does not assume any risk in relation to your use of this website. For more information, please go to <https://www.hcl-software.com/appscan/>.

Copyright © 2008, 2017, IBM Corporation, All rights reserved. Copyright © 2017, 2026, HCL Technologies, Ltd., All rights reserved.

demo.testfire.net/bank/transaction.jsp

Ask Gemini

Sign Off | Contact Us | Feedback | Search

Go

AltoroMutual

MY ACCOUNT

I WANT TO ...

- View Account Summary
- View Recent Transactions
- Transfer Funds
- Search News Articles
- Customize Site Language

ADMINISTRATION

- Edit Users

PERSONAL

SMALL BUSINESS

INSIDE ALTORO MUTUAL

Recent Transactions

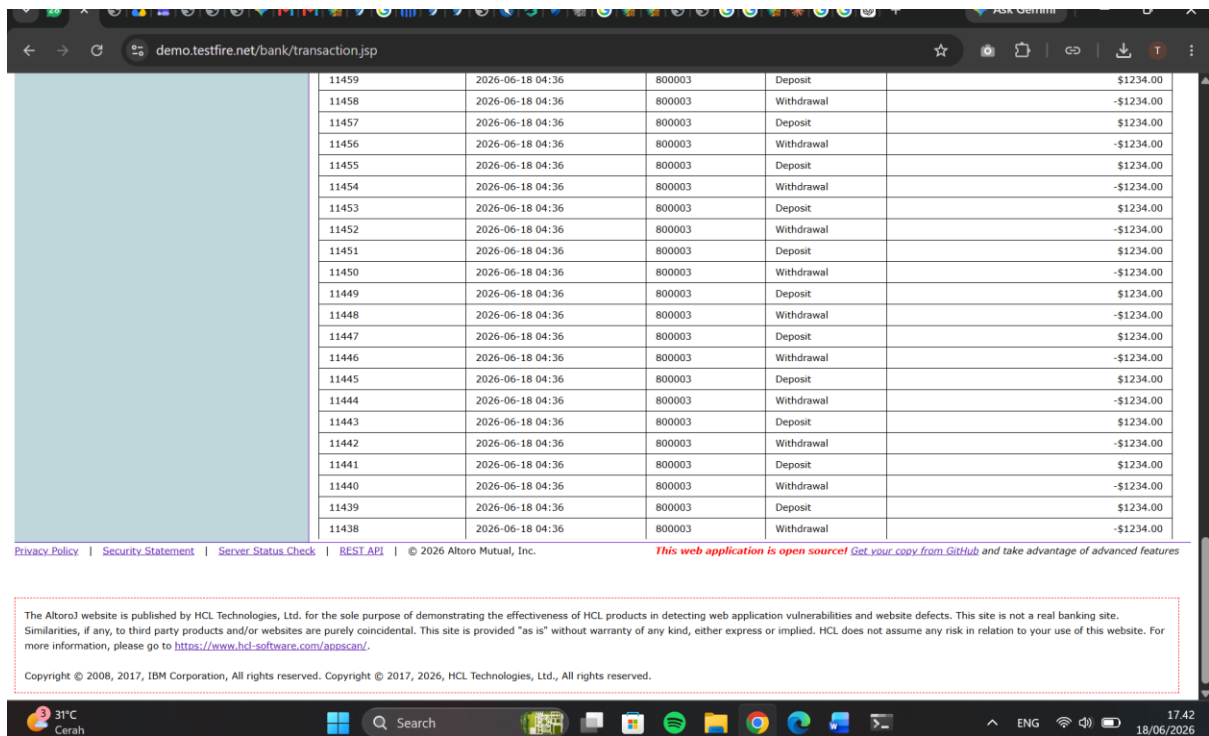
After yyyy-mm-dd Before yyyy-mm-dd Submit

Transaction ID	Transaction Time	Account ID	Action	Amount
11537	2026-06-18 04:40	800003	Deposit	\$1234.00
11536	2026-06-18 04:40	800003	Withdrawal	-\$1234.00
11535	2026-06-18 04:40	800003	Deposit	\$1234.00
11534	2026-06-18 04:40	800003	Withdrawal	-\$1234.00
11533	2026-06-18 04:40	800003	Deposit	\$1234.00
11532	2026-06-18 04:40	800003	Withdrawal	-\$1234.00
11531	2026-06-18 04:40	800003	Deposit	\$1234.00
11530	2026-06-18 04:40	800003	Withdrawal	-\$1234.00
11529	2026-06-18 04:40	800003	Deposit	\$1234.00
11528	2026-06-18 04:40	800003	Withdrawal	-\$1234.00
11527	2026-06-18 04:40	800003	Deposit	\$1234.00
11526	2026-06-18 04:40	800003	Withdrawal	-\$1234.00
11525	2026-06-18 04:40	800003	Deposit	\$1234.00
11524	2026-06-18 04:40	800003	Withdrawal	-\$1234.00
11523	2026-06-18 04:40	800003	Deposit	\$1234.00
11522	2026-06-18 04:40	800003	Withdrawal	-\$1234.00
11521	2026-06-18 04:40	800003	Deposit	\$1234.00
11520	2026-06-18 04:40	800003	Withdrawal	-\$1234.00
11519	2026-06-18 04:40	800003	Deposit	\$1234.00
11518	2026-06-18 04:40	800003	Withdrawal	-\$1234.00
11517	2026-06-18 04:36	800003	Deposit	\$1234.00
11516	2026-06-18 04:36	800003	Withdrawal	-\$1234.00

31°C Cerah

Search

ENG 17:41 18/06/2026



11459	2026-06-18 04:36	800003	Deposit	\$1234.00
11458	2026-06-18 04:36	800003	Withdrawal	-\$1234.00
11457	2026-06-18 04:36	800003	Deposit	\$1234.00
11456	2026-06-18 04:36	800003	Withdrawal	-\$1234.00
11455	2026-06-18 04:36	800003	Deposit	\$1234.00
11454	2026-06-18 04:36	800003	Withdrawal	-\$1234.00
11453	2026-06-18 04:36	800003	Deposit	\$1234.00
11452	2026-06-18 04:36	800003	Withdrawal	-\$1234.00
11451	2026-06-18 04:36	800003	Deposit	\$1234.00
11450	2026-06-18 04:36	800003	Withdrawal	-\$1234.00
11449	2026-06-18 04:36	800003	Deposit	\$1234.00
11448	2026-06-18 04:36	800003	Withdrawal	-\$1234.00
11447	2026-06-18 04:36	800003	Deposit	\$1234.00
11446	2026-06-18 04:36	800003	Withdrawal	-\$1234.00
11445	2026-06-18 04:36	800003	Deposit	\$1234.00
11444	2026-06-18 04:36	800003	Withdrawal	-\$1234.00
11443	2026-06-18 04:36	800003	Deposit	\$1234.00
11442	2026-06-18 04:36	800003	Withdrawal	-\$1234.00
11441	2026-06-18 04:36	800003	Deposit	\$1234.00
11440	2026-06-18 04:36	800003	Withdrawal	-\$1234.00
11439	2026-06-18 04:36	800003	Deposit	\$1234.00
11438	2026-06-18 04:36	800003	Withdrawal	-\$1234.00

Berdasarkan gambar yang ditampilkan, serangan **SQL Injection** berhasil dilakukan pada halaman login aplikasi Altoro Mutual sehingga penyerang memperoleh akses sebagai **Admin User** tanpa menggunakan kredensial yang sah. Keberhasilan serangan ditunjukkan dengan munculnya halaman utama yang menampilkan pesan "**Hello Admin User**" serta menu **Administration** yang berisi fitur **Edit Users**. Selain itu, penyerang juga dapat mengakses informasi akun dan melihat data transaksi pada sistem. Kondisi ini menunjukkan bahwa mekanisme autentikasi aplikasi memiliki kelemahan dalam memvalidasi input pengguna sehingga perintah SQL yang dimasukkan dapat memanipulasi query database dan melewati proses login.

Setelah berhasil masuk sebagai administrator, penyerang memperoleh hak akses yang lebih tinggi dibandingkan pengguna biasa. Hal ini memungkinkan penyerang untuk melihat informasi sensitif, mengakses data transaksi, mengelola akun pengguna, dan berpotensi melakukan perubahan terhadap data yang tersimpan dalam sistem. Dampak dari kerentanan ini sangat berbahaya karena dapat mengancam kerahasiaan, integritas, dan ketersediaan data. Oleh karena itu, aplikasi perlu menerapkan pengamanan seperti penggunaan **prepared statement**, **parameterized query**, validasi input yang ketat, serta pembatasan hak akses pengguna untuk mencegah terjadinya serangan SQL Injection dan akses tidak sah ke sistem.

Cara Mencegah Serangan SQL Injection

SQL Injection merupakan salah satu serangan siber yang memanfaatkan kelemahan aplikasi web dalam memproses input pengguna yang berhubungan dengan database. Serangan ini dapat menyebabkan kebocoran data, perubahan informasi, hingga pengambilalihan akses oleh pihak yang tidak berwenang. Oleh karena itu, diperlukan berbagai langkah pengamanan untuk mencegah terjadinya SQL Injection.

Langkah utama yang harus dilakukan adalah menggunakan **Prepared Statement** atau **Parameterized Query** dalam setiap proses yang berinteraksi dengan database. Teknik ini memisahkan perintah SQL dengan data yang dimasukkan pengguna sehingga input tidak dapat diinterpretasikan sebagai bagian dari perintah SQL. Selain itu, pengembang harus melakukan **validasi dan sanitasi input** untuk memastikan bahwa data yang dimasukkan sesuai dengan format yang diharapkan dan tidak mengandung karakter berbahaya.

Penggunaan hak akses database yang terbatas juga sangat penting. Akun database yang digunakan aplikasi sebaiknya hanya memiliki izin yang diperlukan sehingga jika terjadi serangan, dampaknya dapat diminimalkan. Selanjutnya, aplikasi perlu menerapkan **mekanisme autentikasi dan otorisasi yang kuat** agar pengguna tidak dapat mengakses fitur yang tidak sesuai dengan hak aksesnya.

Penerapan **Web Application Firewall (WAF)** juga dapat membantu mendeteksi dan memblokir pola serangan SQL Injection sebelum mencapai server aplikasi. Selain itu, pengembang harus rutin melakukan pembaruan sistem, framework, dan database untuk menutup celah keamanan yang telah diketahui. Pengujian keamanan secara berkala, seperti vulnerability assessment dan penetration testing, juga diperlukan untuk mengidentifikasi kelemahan sebelum dimanfaatkan oleh penyerang.

Terakhir, aplikasi sebaiknya tidak menampilkan pesan kesalahan database secara langsung kepada pengguna karena informasi tersebut dapat dimanfaatkan oleh penyerang untuk memahami struktur sistem. Dengan menerapkan berbagai langkah keamanan tersebut secara konsisten, risiko serangan SQL Injection dapat diminimalkan sehingga kerahasiaan, integritas, dan ketersediaan data tetap terjaga.